



Carnage

Task 1:-

Eric Fischer from the Purchasing Department at Bartell Ltd has received an email from a known contact with a Word document attachment. Upon opening the document, he accidentally clicked on "Enable Content." The SOC Department immediately received an alert from the endpoint agent that Eric's workstation was making suspicious connections outbound. The pcap was retrieved from the network sensor and handed to you for analysis.

Task: Investigate the packet capture and uncover the malicious activities.

*Credit goes to [Brad Duncan](#) for capturing the traffic and sharing the pcap packet capture with InfoSec community

Answer the questions below

Read the above.

No Answer Needed

Task 2:- Traffic Analysis



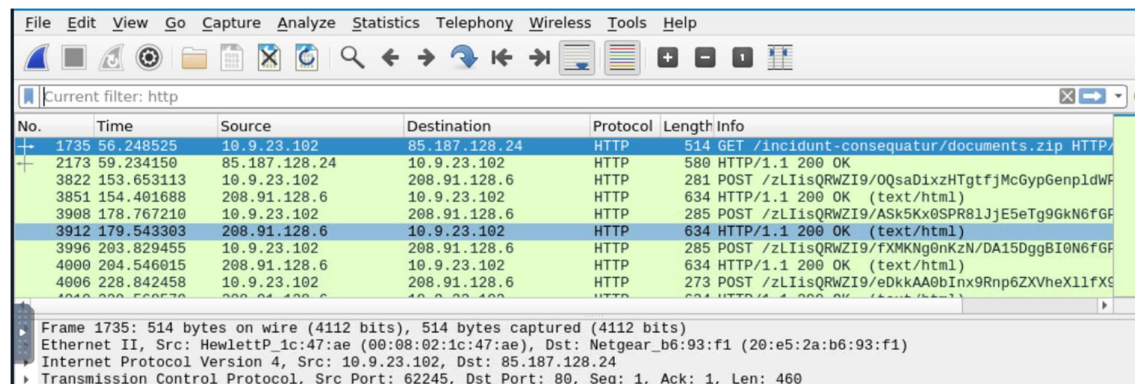
Are you ready for the journey?

Please, load the pcap file in your Analysis folder on the Desktop into Wireshark to answer the questions below.

Answer the questions below

1)What was the date and time for the first HTTP connection to the malicious IP? (answer format: yyyy-mm-dd hh:mm:ss)

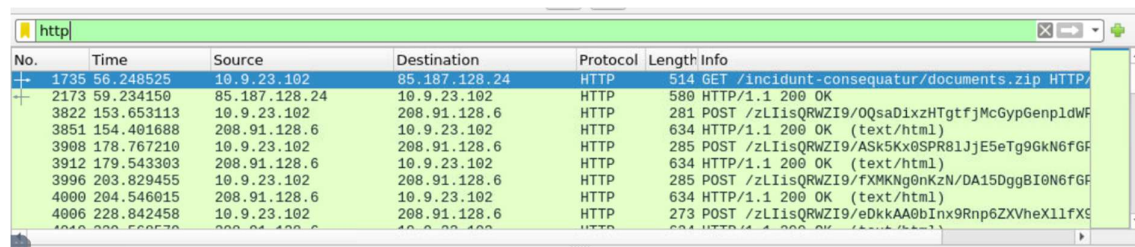
Ans:- 2021-09-24 16:44:38



No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	10.9.23.102	85.187.128.24	HTTP	514	GET /incident-consequatur/documents.zip HTTP/1.1
2173	59.234150	85.187.128.24	10.9.23.102	HTTP	580	HTTP/1.1 200 OK
3822	153.653113	10.9.23.102	208.91.128.6	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWf HTTP/1.1
3851	154.401688	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	178.767210	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/ASK5Kx0SPR81JjE5eTg9GkN6fGF HTTP/1.1
3912	179.543303	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	203.829455	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/fXMKNg0nKzN/DA15DggBI0N6fGF HTTP/1.1
4000	204.546015	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4006	228.842458	10.9.23.102	208.91.128.6	HTTP	273	POST /zLIisQRWZI9/eDkkAA0bInx9Rnp6ZXVheX1lfXS HTTP/1.1

Frame 1735: 514 bytes on wire (4112 bits), 514 bytes captured (4112 bits) on interface 0
Ethernet II, Src: HewlettP_1c:47:ae (00:08:02:1c:47:ae), Dst: Netgear_b6:93:f1 (20:e5:2a:b6:93:f1)
Internet Protocol Version 4, Src: 10.9.23.102, Dst: 85.187.128.24
Transmission Control Protocol, Src Port: 62245, Dst Port: 80, Seq: 1, Ack: 1, Len: 460

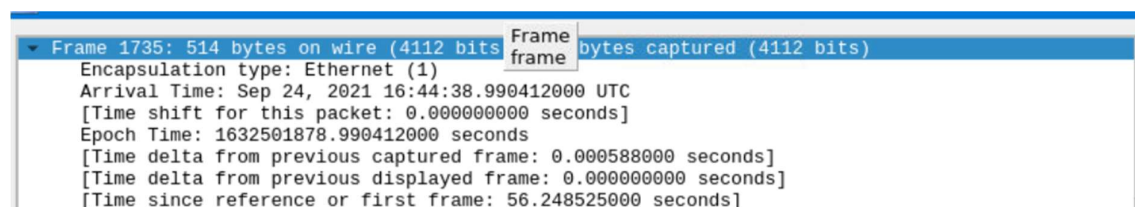
In filter apply http



No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	10.9.23.102	85.187.128.24	HTTP	514	GET /incident-consequatur/documents.zip HTTP/1.1
2173	59.234150	85.187.128.24	10.9.23.102	HTTP	580	HTTP/1.1 200 OK
3822	153.653113	10.9.23.102	208.91.128.6	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWf HTTP/1.1
3851	154.401688	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	178.767210	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/ASK5Kx0SPR81JjE5eTg9GkN6fGF HTTP/1.1
3912	179.543303	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	203.829455	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/fXMKNg0nKzN/DA15DggBI0N6fGF HTTP/1.1
4000	204.546015	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4006	228.842458	10.9.23.102	208.91.128.6	HTTP	273	POST /zLIisQRWZI9/eDkkAA0bInx9Rnp6ZXVheX1lfXS HTTP/1.1

The first connection is the first http packet

After opening it



Frame	bytes on wire (4112 bits)	Frame	bytes captured (4112 bits)
Encapsulation type: Ethernet (1)			
Arrival Time: Sep 24, 2021 16:44:38.990412000 UTC			
[Time shift for this packet: 0.000000000 seconds]			
Epoch Time: 1632501878.990412000 seconds			
[Time delta from previous captured frame: 0.000588000 seconds]			
[Time delta from previous displayed frame: 0.000000000 seconds]			
[Time since reference or first frame: 56.248525000 seconds]			

After expanding Frame you can see the Arrival Time.

2)What is the name of the zip file that was downloaded?

Ans:-documents.zip



No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	10.9.23.102	85.187.128.24	HTTP	514	GET /incident-consequatur/documents.zip HTTP/1.1

In the first http packet you can see the info the zip file name is given

3)What was the domain hosting the malicious zip file?

Ans:- attirenepal.com

The first connection is the first http packet

After opening it

```
Hypertext Transfer Protocol
  GET /incidunt-consequatur/documents.zip HTTP/1.1\r\n
  Host: attirenepal.com\r\n
  Connection: keep-alive\r\n
  Upgrade-Insecure-Requests: 1\r\n
  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) C
  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,
  Accept-Encoding: gzip, deflate\r\n
  Accept-Language: en\r\n
```

Expand the Hypertext Transfer Protocol then we will find the Host

4)Without downloading the file, what is the name of the file in the zip file?

Ans:- chart-1530076591.xls

No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	10.9.23.102	85.187.128.24	HTTP	514	GET /incidunt-consequatur/documents.zip HTTP/1.1
2173	59.234150	85.187.128.24	10.9.23.102	HTTP	580	HTTP/1.1 200 OK
3822	153.653113	10.9.23.102	208.91.128.6	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpIdwF
3851	154.401688	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	178.767210	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/ASK5Kx0SPR81JjE5eTg9GkN6fGF
3912	179.543303	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	203.829455	10.9.23.102	208.91.128.6	HTTP	285	POST /zLIisQRWZI9/fXMKNg0nKzN/DA15DggBI0N6fGF
4000	204.546015	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4006	228.842458	10.9.23.102	208.91.128.6	HTTP	273	POST /zLIisQRWZI9/eDkkAA0bInx9Rnp6ZXVheX1lfX9

The frame number 2173 is the response for that request

After opening it

Under Data

Data (198125 bytes)

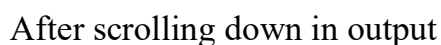
Data: 504b0304140000000800e8643853fc61eef62f05030000d6030014001c0063686172742d...

[Length: 198125]

00000000	01010000	01001011	00000011	00000100	00010100	00000000	00000000	00000000	PK.....
00000008	00001000	00000000	11101000	01100100	00111000	01010011	11111100	01100001	...d8S.a
00000010	11101110	11110110	00101111	00000101	00000011	00000000	00000000	11010110	.../.....
00000018	00000011	00000000	00010100	00000000	00011100	00000000	01100011	01101000	...ch
00000020	01100001	01110010	01110100	00101101	00110001	00110101	00110011	00110000	art-1530
00000028	00110000	00110111	00110110	00110101	00111001	00110001	00101110	01111000	076591.x
00000030	01101100	01110011	01010101	01010100	00001001	00000000	00000011	11000011	lsUT...
00000038	10011100	01001101	01100001	10111010	10011101	01001101	01100001	01110101	..Ma..Mau
00000040	01111000	00001011	00000000	00000001	00000100	00000000	00000000	00000000	x.....
00000048	00000000	00000100	00000000	00000000	00000000	00000000	11101100	01011011	[
00000050	01110111	01011100	00010100	11010111	11011010	00111110	10111011	00001100	w\...>..
00000058	01011011	11101000	01010101	01000000	00010110	01011000	01000000	00101100	[.U@.X@.
00000060	10000000	00000010	01001011	10010001	00100110	10001000	00001101	10001001	..K.&...

- Copy Bytes as Hex + ASCII Dump
 - ...as Hex Dump
 - ...as Printable Text
 - ...as a Hex Stream
 - ...as Raw Binary
 - ...as Escaped String
- Show bytes as hexadecimal
 - ...as bits
 - Show text based on packet
 - ...as ASCII
 - ...as EBCDIC

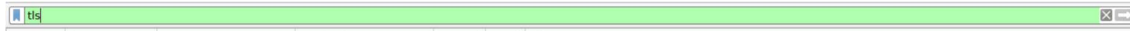
Here I used Cyber Chef



7) Malicious files were downloaded to the victim host from multiple domains. What were the three domains involved with this activity?

Ans:- finejewels.com.au, thietbiagt.com, new.americold.com

In display filter apply tls filter because the hint was given as to check https traffic



And the hint given was to Narrow down the timeframe from 16:45:11 to 16:45:30

To change the time format go to view and time display format and we can change the time format to UTC because the hint is given in that format

To change the source and destination address to domain names we can use view and go to Name Resolution and then we can change

After changing

No.	Time	Source	Destination	Protocol	Length	Info
2411	2021-09-24 16:45:08.253247	DESKTOP-I0JC6RB.goi...	www.tm.ak.prd.aadg...	TLSv1.2	657	Application Data
2413	2021-09-24 16:45:08.388150	1-0007.1-msedge.net	DESKTOP-I0JC6RB.goi...	TLSv1.2	563	Application Data
2414	2021-09-24 16:45:08.419871	www.tm.ak.prd.aadg...	DESKTOP-I0JC6RB.goi...	TLSv1.2	189	Change Cipher Spec, Encrypted Handshake Message
2417	2021-09-24 16:45:08.752073	www.tm.ak.prd.aadg...	DESKTOP-I0JC6RB.goi...	TLSv1.2	1044	Application Data
2420	2021-09-24 16:45:11.304916	DESKTOP-I0JC6RB.goi...	finejewels.com.au	TLSv1.2	218	Client Hello
2433	2021-09-24 16:45:12.322204	finejewels.com.au	DESKTOP-I0JC6RB.goi...	TLSv1.2	1414	Server Hello
2436	2021-09-24 16:45:12.322676	finejewels.com.au	DESKTOP-I0JC6RB.goi...	TLSv1.2	618	Certificate, Server Key Exchange, Server Hello Done
2438	2021-09-24 16:45:12.328971	DESKTOP-I0JC6RB.goi...	finejewels.com.au	TLSv1.2	147	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
2440	2021-09-24 16:45:12.827837	finejewels.com.au	DESKTOP-I0JC6RB.goi...	TLSv1.2	491	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message, Application Da...
2442	2021-09-24 16:45:12.832334	DESKTOP-I0JC6RB.goi...	finejewels.com.au	TLSv1.2	141	Application Data
2444	2021-09-24 16:45:12.832454	DESKTOP-I0JC6RB.goi...	finejewels.com.au	TLSv1.2	92	Application Data
2446	2021-09-24 16:45:12.832641	DESKTOP-I0JC6RB.goi...	finejewels.com.au	TLSv1.2	204	Application Data

We can see the domain names listed b/w the time frames

Another domain name

3004	2021-09-24 16:45:21.101071	DESKTOP-I0JC6RB.goi...	wms.notify.trafficm...	TLSv1.2	100	
3006	2021-09-24 16:45:21.278876	wms.notify.trafficm...	DESKTOP-I0JC6RB.goi...	TLSv1.2	174	
3009	2021-09-24 16:45:21.314012	DESKTOP-I0JC6RB.goi...	thietbiagt.com	TLSv1.2	244	
3012	2021-09-24 16:45:21.743047	thietbiagt.com	DESKTOP-I0JC6RB.goi...	TLSv1.2	1402	
3014	2021-09-24 16:45:21.743265	thietbiagt.com	DESKTOP-I0JC6RB.goi...	TLSv1.2	1514	
3015	2021-09-24 16:45:21.743272	thietbiagt.com	DESKTOP-I0JC6RB.goi...	TLSv1.2	222	
3018	2021-09-24 16:45:21.749716	DESKTOP-I0JC6RB.goi...	thietbiagt.com	TLSv1.2	147	
3229	2021-09-24 16:45:25.731116	DESKTOP-I0JC6RB.goi...	new.americold.com	TLSv1.2	204	
3233	2021-09-24 16:45:26.038433	cs9.wpc.v0cdn.net	DESKTOP-I0JC6RB.goi...	TLSv1.2	100	
3236	2021-09-24 16:45:26.039411	new.americold.com	DESKTOP-I0JC6RB.goi...	TLSv1.2	1514	
3239	2021-09-24 16:45:26.039548	new.americold.com	DESKTOP-I0JC6RB.goi...	TLSv1.2	500	
3242	2021-09-24 16:45:26.047029	DESKTOP-I0JC6RB.goi...	new.americold.com	TLSv1.2	100	

So three domain names are finejewels.com.au, thietbiagt.com, new.americold.com

8) Which certificate authority issued the SSL certificate to the first domain from the previous question?

Ans:- GoDaddy

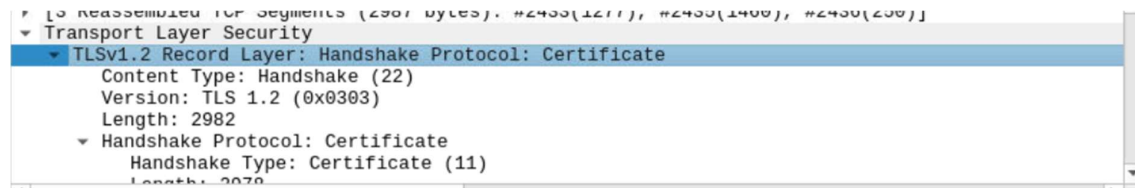
From previous question the first domain is finejewels.com

Let us inspect this packet

2436 2021-09-24 16:45:12.322676 finejewels.com.au DESKTOP-I0JC6RB.qoi... TLSv1.2 618 Certificate, Server Key Exc

After opening it

Expand the TLS



And we will navigate to certificates and then issuer and we will find the issuer

- signature (sha256WithRSAEncryption)
- issuer: rdnSequence (0)
 - rdnSequence: 6 items (id-at-commonName=Go Daddy Secure Certificate Authority -

So the authority is GoDaddy

9)What are the two IP addresses of the Cobalt Strike servers? Use VirusTotal (the Community tab) to confirm if IPs are identified as Cobalt Strike C2 servers. (answer format: enter the IP addresses in sequential order)

Ans:- 185.106.96.158, 185.125.204.174

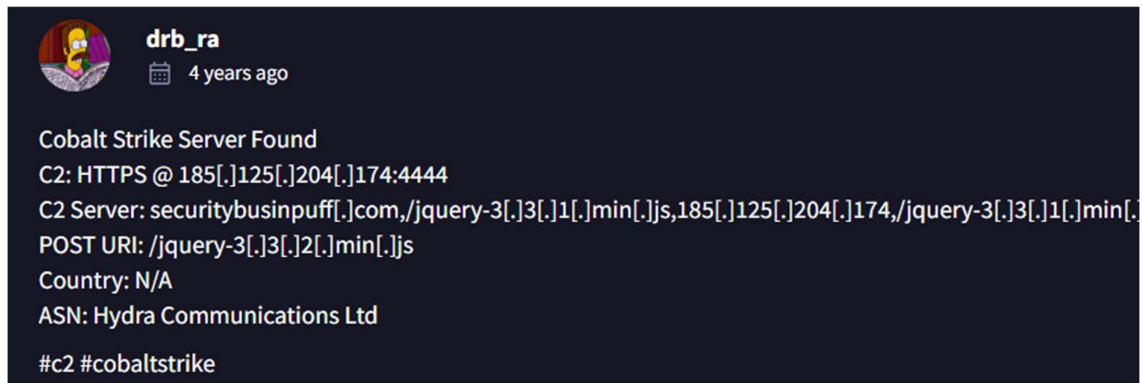
Hint:-Check the Conversations menu option

To go to Conversations menu click on Statistics and then Conversations

The default port is 8080 so lets look at 8080

Ethernet - 8		IPv4 - 109		IPv6		TCP - 447		UDP - 256	
Address A	Port A	Address B	Port B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A
23.111.114.52	65400	10.9.23.102	63557	18002	15M	12281	15M	5721	6
10.9.23.102	63498	10.9.23.5	49675	13	4202	7	1674	6	
10.9.23.5	49675	10.9.23.102	49672	21	5646	10	3000	11	
10.9.23.102	49677	10.9.23.5	49667	65	21k	33	14k	32	
10.9.23.102	49698	10.9.23.5	49667	24	7003	13	4388	11	
10.9.23.102	63363	10.9.23.5	49667	24	6994	13	4379	11	
10.9.23.102	63372	10.9.23.5	49667	22	6743	12	4322	10	
10.9.23.102	63382	10.9.23.5	49667	17	2646	9	1446	8	
10.9.23.102	63417	10.9.23.5	49667	13	2042	7	890	6	
10.9.23.102	63488	10.9.23.5	49667	17	2646	9	1446	8	
10.9.23.102	63538	10.9.23.5	49667	22	6743	12	4322	10	
10.9.23.102	63685	10.9.23.5	49667	17	2646	9	1446	8	
10.9.23.102	63410	185.125.204.174	8080	255	235k	81	5023	174	
10.9.23.102	63413	185.125.204.174	8080	29	10k	13	1539	16	
10.9.23.102	63423	185.125.204.174	8080	27	8501	14	1547	13	
10.9.23.102	63438	185.125.204.174	8080	23	8236	10	1367	13	
10.9.23.102	63445	185.125.204.174	8080	25	8372	12	1439	13	
10.9.23.102	63449	185.125.204.174	8080	23	8641	10	1367	13	
10.9.23.102	63450	185.125.204.174	8080	24	8195	11	1356	13	
10.9.23.102	63451	185.125.204.174	8080	24	8318	11	1385	13	
10.9.23.102	63452	185.125.204.174	8080	23	8236	10	1367	13	
10.9.23.102	63453	185.125.204.174	8080	24	8372	11	1385	13	
10.9.23.102	63455	185.125.204.174	8080	24	8372	11	1385	13	

The IP address was 185.125.204.174 let's verify with VirusTotal



Other IP

10.9.23.102	63481	185.125.204.174	443	27	10k
10.9.23.102	63508	185.125.204.174	443	24	8285
10.9.23.102	63541	185.125.204.174	443	25	8421
10.9.23.102	63543	185.125.204.174	443	20	4918
10.9.23.102	63447	185.106.96.158	80	187	220k
10.9.23.102	63448	185.106.96.158	80	9	1325
10.9.23.102	63460	185.106.96.158	80	9	1325
10.9.23.102	63495	185.106.96.158	80	11	1498

10)What is the Host header for the first Cobalt Strike IP address from the previous question?

Ans:- ojsp.verisign.com

The first IP was 185.106.96.158 again we visit VirusTotal

After inspecting the header is

ojsp.verisign.com

11)What is the domain name for the first IP address of the Cobalt Strike server? You may use VirusTotal to confirm if it's the Cobalt Strike server (check the Community tab).

Ans:- survmeter.live

The first IP was 185.106.96.158

To see it we can use the filter ip.addr == 185.106.96.158

ip.addr == 185.106.96.158						
No.	Time	Source	Destination	Protocol	Length	Info
6323	2021-09-24 16:55:08.330879	DESKTOP-I0JC6RB.goi...	survmeter.live	TCP	66	63447 → http(80) [SYN] Seq=

The domain name is survmeter.live

12)What is the domain name for the second IP address of the Cobalt Strike server? You may use VirusTotal to confirm if it's the Cobalt Strike server (check the Community tab).

Ans:-

The second IP was 185.125.204.174

To see it we can use the filter ip.addr == 185.125.204.174

6312	2021-09-24 16:55:05.905471	securitybusinpuff.c...	DESKTOP-I0JC6RB.goi...	TCP	54	http-alt(8080) → 63445 [ACK]
------	----------------------------	------------------------	------------------------	-----	----	------------------------------

The domain name is securitybusinpuff.com

13)What is the domain name of the post-infection traffic?

Ans:-

Hint:- Filter post http traffic

To apply filter we use http.request.method==POST

3822	2021-09-24 16:46:16.395000	DESKTOP-I0JC6RB.goi...	maldivhost.net	HTTP	281	POST /zLIisQRWZI9/00saDixzH
------	----------------------------	------------------------	----------------	------	-----	-----------------------------

The domain name is maldivhost.net

14)What are the first eleven characters that the victim host sends out to the malicious domain involved in the post-infection traffic?

Ans:- zLIisQRWZI9

We will inspect this packet

3822	2021-09-24 16:46:16.395000	DESKTOP-I0JC6RB.goi...	maldivhost.net	HTTP	281	POST /zLIisQRWZI9/00saDixzH
------	----------------------------	------------------------	----------------	------	-----	-----------------------------

After opening it

```

Transmission Control Protocol, Src Port: 65535 (65535), Dst Port: http
Hypertext Transfer Protocol
  POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= HTTP/1.1\r\n
    Host: maldivehost.net\r\n
  Content-Length: 112\r\n

```

We can see the POST request the first 11 characters are zLIisQRWZI9

15)What was the length for the first packet sent out to the C2 server?

Ans:-281

As we can see the first packet

```

3822 2021-09-24 16:46:16.395000 DESKTOP-I0JC6RB.qoi... maldivehost.net HTTP 281 POST /zLIisQRWZI9/OQsaDixzH

```

The length is 281

16)What was the Server header for the malicious domain from the previous question?

Ans:- Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

To get this first from the first packet we right click and got to follow and then tcp stream

```

POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112

Dw8YBxsEGmYFAAEJfR4NQkMmLTyqZDk5KyQm0yRGQg1xEBo4Lzk/
EyYrMi1hOT8vIyM7IhcNPzsOKjguFvgkLSIiJCxFrgwFagIIDQUZGB0FD0JF

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4
X-Powered-By: PHP/5.6.40
Content-Length: 302
Strict-Transport-Security: ...max-age=15552000...
Connection: close
Content-Type: text/html; charset=UTF-8

eXp7QUVCQ0FBfn15eX1/
enN8ekJBQ0JGQnpzewJ+extleH1lf3xBRUJDQUELDhkAGAAAbZwIDBqh8GQ5GQicqNS510D4oICc6I0VGCHAXGTWu0DgQIio
zKmI9P14kID8jFgo8Pw8rPy0TGSUqISY1LUJFCAQDBQsJBBgfGQE0Q0JBRUJDQUEBBAQ0QUVCQ0FBAQQEDkFFQkNBQQEEBA
5BRUJDQUFCQUNCrkJGQEJFRUZHQUVGQUdGRkZCQEZBRUJDQUFCQUNCrkJGQEJFRUZHQUVGQUc=

```

Here we can see the header

17)The malware used an API to check for the IP address of the victim's machine. What was the date and time when the DNS query for the IP check domain occurred? (answer format: yyyy-mm-dd hh:mm:ss UTC)

Ans:- 2021-09-24 17:00:04

We use a filter frame contains "api" which filters the packets where the api is used and from here we check for dns query



24149 2021-09-24 17:00:04.233864 goingfortune-dc.goi... DESKTOP-I0JC6RB.goi... DNS 299 Standard query response 0xc

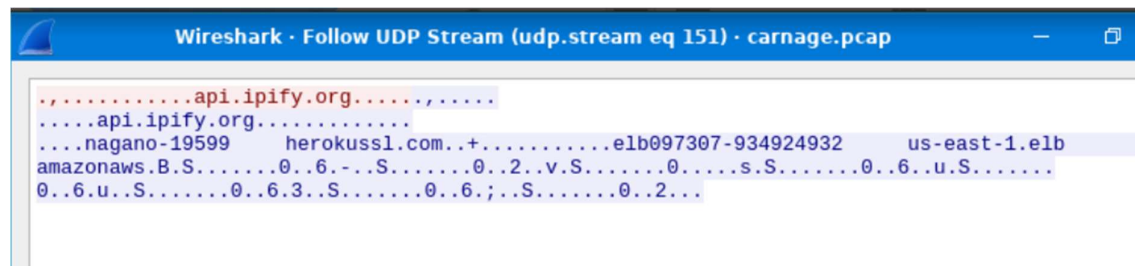
This is the packet

So the UTC time is 2021-09-24 17:00:04

18)What was the domain in the DNS query from the previous question?

Ans:- api.ipify.org

To get this from above question packet we right click and got to follow and then udp stream



Wireshark · Follow UDP Stream (udp.stream eq 151) · carnage.pcap

.....api.ipify.org.....,.....
....api.ipify.org.....
....nagano-19599 herokuss1.com..+.....elb097307-934924932 us-east-1.elb
amazonaws.B.S.....0..6.-..S.....0..2..v.S.....0.....s.S.....0..6..u.S.....
0..6.u..S.....0..6.3..S.....0..6.;..S.....0..2...

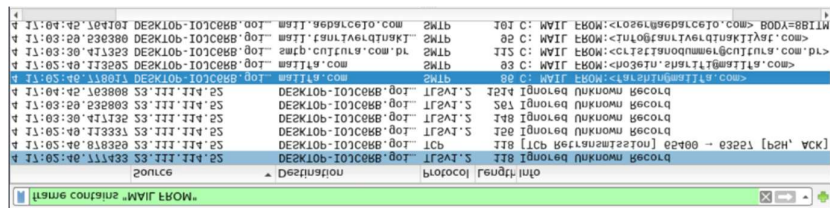
The domain name is api.ipify.org

19)Looks like there was some malicious spam (malspam) activity going on.

What was the first MAIL FROM address observed in the traffic?

Ans:- farshin@mailfa.com

To get this we use the filter frame contains “MAIL FROM”

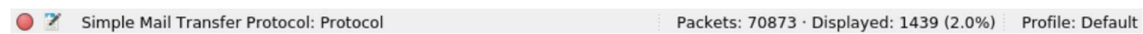


So the first mail for mail from is farshin@mailfa.com

20)How many packets were observed for the SMTP traffic?

Ans:-1439

Use the filter smtp and look at the bottom of status bar



No.of packets are 1439